

Federating Trust Perimeters: Extending Industry IAM with DLT-Based Governance

Carlo Segat

Service-centric Networking

Technische Universität Berlin / T-Labs

Berlin, Germany

carlo.segat@tu-berlin.de

Abstract—Digital systems are becoming more integrated, autonomous, and cooperative. AI agents, future mobile networks, and machine-to-machine economies point to one trend: spontaneous, cross-organizational, unplanned interactions between non-human entities (NHEs). Trust establishment for them remains an open problem. Federation is the natural candidate, but established approaches, from OpenID Federation 1.0 and SAML to Federated Identity Management, presuppose what this setting denies them: manual, ahead-of-time configuration and a common trust anchor, whether pre-established members or a shared provider. Trust domains must therefore federate without being prefigured to do so: plan for unplanned interactions. This paper examines whether prominent Identity and Access Management (IAM) approaches, namely SPIRE, Workload Identity Federation (WIF), and OpenID Federation 1.0, can support such federation. Drawing requirements from disparate fields (medical, mobile networks, agentic AI), it argues that SPIRE is the most promising starting point, but needs three extensions to meet them all: token exchange, letting a home domain mint scoped, audience-bound tokens from a foreign workload’s SPIFFE Verifiable Identity Document (SVID); remote attestation, so a trust decision targets a specific workload rather than a whole domain; and a distributed-ledger layer that anchors trust roots, carries federation governance, and publishes the shared keys the other two depend on.

Index Terms—Distributed ledger, identity, OAuth, OpenID Federation 1.0, SPIFFE, SPIRE, Workload Identity Federation

I. INTRODUCTION AND MOTIVATION

The boundaries between digital systems are dissolving. Former silos, cleanly split into consumers and producers, are now interdependent in ways that challenge pre-established orders. Organizations collaborate not only through legal and business agreements but by integrating their systems technically, increasingly at the application layer (L7). One symptom is stakeholder proliferation within any single domain. This paper argues that tomorrow’s digital systems must, by design, plan for unplanned interactions. Three trends in three separate domains illustrate the shift.

5G and Beyond 1G-era mobile network operators (MNOs) were vertically integrated, managing the system end-to-end [1]. Successive generations decoupled infrastructure from services, pushing operators toward delegation and outsourcing, multiplying stakeholders and fragmenting the once-monolithic system. 5G was the milestone: cloud computing became the paradigm for network functions (NFs) and, through software-defined networking, for networking itself. The resulting heterogeneity is already visible: Telefónica runs non-real-time

NFs (mostly analytics) in GCP [2], and Amazon partners with Verizon and Vodafone to extend AWS to the MNOs’ edge [3]. Private networks tighten these relationships further. Their stringent requirements make the Service Level Agreement (SLA) contractually central: it encodes latency, reliability, and availability targets on which production safety can directly depend. Were those targets fixed at signing, the vertical would be a mere consumer of the MNO service. In practice they must be traded off against the dynamism of production processes and network conditions, a decision requiring domain knowledge the vertical may not want to share. Verticals therefore need a structural role in SLA governance, since the MNO cannot fully represent their interests. Looking ahead, 6G is expected to build on device-to-device sidelink, letting user equipment relay traffic rather than only consume the network. As subscriber devices become, in part, infrastructure, the line between operator and user blurs [4]. A unified access-control model for NFs within and across core networks remains active work, as a May 2026 3GPP S3 key issue shows [5]. Options borrowed from web practice exist, but open questions and configuration sprawl raise security concerns [6].

eHealth Digital health, or eHealth, is a broad term encompassing intersections of technology and medicine. Tracing the high-level history of digital health reveals the same trend of increased heterogeneity of stakeholders and collaboration. A striking fact is that it was only recently that academia recognized the potential of patients themselves to directly improve the state of medicine. Examples include the e-patient white paper [7] and the BMJ Patient Panel [8]. Those are examples of how the idea of an unquestionable doctor taking unilateral decisions on behalf of a subordinated patient has been changing. Technology is the enabler for patients to emerge from their passive role. Conversely, technology is also the only plausible means of managing the new complexities that this collaborative relationship brings about. Although the medical domain has been traditionally slow and cautious in adopting innovation, recent trends show the dynamics may be changing. One example is the FDA Pre-Cert pilot (2017-2022), which explored a novel eHealth software lifecycle model intended to reduce per-release reviews [9]. Despite decades of progress, eHealth still lacks a single global data standard, with competing formats and interoperability constraints persisting [10]. These problems compound across applications, such

as practice management software, pharmacy and laboratory systems, and dental management tools, which are typically built by different vendors that do not always prioritize interoperability. The result is data silos, offering no complete view of a patient’s clinical picture. Useful, but hard-to-integrate sources such as insurance claims and user-generated data from wearables and self-measurements compound the problem [11]. The eHealth ecosystem is judged as a fragmented one [12] and among the many contributing factors to this state, one that is often cited is the lack of standardization in identity systems [13], and the lack of incentive structure for data sharing [14]. The role of AI in the medical world is one of acceleration. Although diagnosis and drug discovery are often cited as the areas of strongest AI contribution [15], others, including administrative efficiency and personalization are also relevant [16], [17]. The 2018 introduction of an official AI policy by the American Medical Association marks a milestone in the integration of AI into the medical world [18].

Agentic AI The domain of artificial intelligence has shifted from being exclusively made up of specialized models privately managed to general-purpose and open ones adopted by a broader and more diverse public. An AI agent ecosystem is constituted by heterogeneous stakeholders by design. There are data owners, the source of the data that models are trained on [19]; infrastructure providers, whose role grows with the compute demands of modern models [20]; chip manufacturers, exemplified by NVIDIA’s rapid ascent [21]; and finally users, whose interactions feed precious data back into it [22]. An AI agent’s goals can be open-ended, so it cannot always anticipate the APIs and tools it will need, making collaboration with diverse parties essential [23]. To overcome scalability limitations such as those related to context windows or knowledge gaps, or to coordinate complex decisions, agents may also interact with each other [24]. In multi-agent systems (MAS), this can be confined to the boundaries of the same organization, but cross-organizational MAS are also foreseen.

Agentic AI exacerbates the trust problems of the other domains: mobile and medical can bound their stakeholders to an extent, whereas an agent’s participant scope is unbounded, under-specified goals and strategies being a distinctive feature. The Agent2Agent (A2A) protocol targets cross-organizational use but defines no Identity and Access Management (IAM) of its own, advertising authentication schemes in signed agent cards (OAuth 2.0, mutual TLS, OpenID Connect (OIDC)) while leaving federation, authorization, orchestration, and context transfer to implementers [25]. The Agent Network Protocol (ANP) goes further: Decentralized Identifier (DID) authentication via the `did:wba` method, a peer-to-peer model, dynamic protocol negotiation, and an Agent Description Document for discovery [26]. Still, it defines no formal authorization model; because `did:wba` and its `.well-known` discovery both resolve over HTTPS, they inherit the weaknesses of DNS and web public-key infrastructure (PKI) (e.g., DID-document spoofing, insecure hosting); and negotiating machine-level protocols in natural language introduces failure-prone non-determinism [27]. Open

Finance is yet another example: regulation forces banks to expose customer data, opening the silo to a diverse crowd of third-party providers.

Across these domains, the same structural problems recur.

- *Disaggregation and heterogeneity.* Independent stakeholders and heterogeneous components rule out a common set of security assumptions; trust must be established explicitly and verifiably across technological boundaries.
- *Security.* Unplanned interactions invite unforeseen failures and enlarge the attack surface.
- *Ephemeral network position.* Cloud patterns make network locations unstable, undermining layer-3 and layer-4 identifiers as an IAM basis [28].
- *Scale.* Not a few long-lived entities, but potentially millions of ephemeral ones.

Data silos have many causes, legal ones not least; a technical one is the absence of an automatic, transparent, and shared mechanism for establishing trust. Such frictions slow digital ecosystems moving toward broader and deeper application-layer integration. This paper contributes an analysis of established IAM solutions as the basis for designing an open, cross-organizational, flexible trust establishment mechanism for the digital ecosystems of tomorrow. None of them satisfactorily addresses trust-anchoring, or governance more generally, which is of particular relevance in a multi-stakeholder identity system: all rely on centralized or out-of-band coordination, leaving a single point of compromise and no tamper-evident record of federation membership. This gap, as this paper argues, can be appropriately filled by distributed ledger technology (DLT).

II. RELATED WORK

SPIFFE & SPIRE

SPIRE, the reference implementation of the SPIFFE specification, is a vendor-neutral, cloud-native framework for workload identity. It solves the problem of provisioning credentials to ephemeral and dynamically scheduled workloads in a secretless manner, enabling workload authentication. What sets SPIRE apart from other IAM solutions is the focus on operational automation. Once initial setup is performed, a devops engineer can manage the entire lifecycle of thousands of certificates by means of a few configuration objects. SPIRE deployments scale by flexibly supporting many topologies (multiple Servers, hierarchies, etc.), including, importantly for this paper, federated ones [29].

One half of Figure 1 (with the exclusion of the circled interactions) illustrates the architecture of a SPIRE deployment within one trust domain. The Server acts as the issuer, signing the credentials (known as SVIDs) of all other entities. A Workload manages its SVID via the Workload API, which is exposed by the Agent. An Agent manages a number of workloads which must be co-located on the same host, because importantly, the Workload API is by design an unauthenticated interface. A Server establishes trust in its Agents via Agent Attestation, in which the Agent proves the host identity

to the server (e.g., deployment-time secrets, cloud-provider-issued documents, or trusted platform modules). An Agent establishes trust in a Workload via Workload Attestation, in which the Workload’s identity is proven. Concretely, the Agent interrogates the platform, querying the runtime (the operating system, Kubernetes, the container runtime) to check a workload’s scheduling information.

SPIFFE strictly solves authentication. Authorization needs other techniques such as policy engines (e.g., Open Policy Agent) and separate permissions-carrying credentials.

OAuth

OAuth 2.0 is the de-facto framework for delegated authorization, defined by RFC 6749 [30]. Over the years it has accumulated many extensions, such as token revocation (RFC 7009), token introspection (RFC 7662), dynamic client registration (RFC 7591), and token exchange (RFC 8693). Importantly, OAuth is not a tightly defined IAM approach on its own but rather a toolbox of endpoints, grant types, and token semantics from which concrete deployments are assembled. RFC 6749 itself admits it is “likely to produce a wide range of non-interoperable implementations” [30, §1.8]. OAuth covers both human-facing and machine-to-machine (M2M) scenarios. Its general approach is the delegation of authorization: rather than sharing credentials, a resource owner (RO) authorizes a client to receive a scoped access token, which the client then presents to a resource server. Whereas the human flow issues a token only after the RO consents (by issuing an authorization grant), the M2M case uses the Client Credentials grant (RFC 6749, §4.4): with no user to consent, no authorization grant is needed. The client is effectively its own resource owner and authenticates directly to the authorization server (AS) with its own credentials to obtain a token.

Workload Identity Federation

Workload Identity Federation (WIF) is best understood as an emerging, cloud-vendor-driven practice rather than a single standard. The term and the workload-centric practice were introduced by Google Cloud in 2021 [31] and have been adopted by other providers. WIF’s goal is to let a workload, often running outside the target cloud (on-premises, in another cloud, or in a CI/CD pipeline), access cloud resources without long-lived service account keys [31]. WIF reuses building blocks from both OAuth and OIDC. Token exchange (RFC 8693 [32]) is the central piece: the workload presents a credential from its own issuer to a Security Token Service (STS), which validates it and returns a security token that can be used to directly access a protected resource. Figure 2 illustrates how Workload B asks the STS in A for a token (step 3); the STS fetches B’s public keys to validate the request (step 4); once the STS has minted and returned a token, Workload B uses it to initiate communication with Workload A (step 5); Workload A may, if not cached, fetch the keys of the local issuer to validate the token sent by B (step 6). Although for simplicity the paper assumes OIDC, the type

of credential is flexible. Google Cloud, for example, supports SAML signed assertions and X.509 client certificates, among others [31]. WIF’s trust model is bilateral: each external issuer must be registered individually with the STS for its tokens to be accepted, a manual, per-issuer step.

OIDC and OpenID Federation 1.0

OIDC Core 1.0 [33] is an identity layer on top of OAuth 2.0 adding authentication. Its core construct is the ID Token, a JWT in which an OpenID Provider (OP) asserts a subject’s identity to a Relying Party (RP) through a set of mandatory claims. OIDC also defines a discovery mechanism: the OP publishes its provider metadata as a JSON document at a well-known endpoint, advertising among other entries the URL of its JWKS Endpoint, from which the RP fetches the public keys that verify ID Token signatures. While OIDC’s authentication ceremonies are designed around human logins and browsers, its model can be applied to M2M, where the subject is, for example, a workload and the OP its issuer. Nonetheless, OIDC’s trust model is bilateral: each RP-OP pair must be set up manually, which does not scale across domains. OpenID Federation 1.0 [34] improves this by making the model multilateral and, to an extent, by automating trust establishment via OIDC’s very own hierarchical PKI. The communication diagram in Section A visualizes the flow. In the OIDC PKI, all entities publish signed Entity Statements: self-issued JSON documents containing metadata about the entity. Intermediate authorities (known as Intermediates) additionally publish Subordinate Statements (i.e., a list of leaf entities they vouch for). Trust Anchors (TAs) sign the Intermediates’ Entity Statements and must be pre-trusted by clients. The fact that trust can be chained back to a commonly trusted TA allows OPs to trust unregistered RPs, a mechanism formally known as Automatic Registration. Trust Marks may further attest an entity’s conformance to a federation profile. As stated, the goal of OIDC is for an RP to obtain a subject’s identity information from the subject’s OP. This is the case for some prominent use cases of OpenID Federation 1.0. For example, in the EU Digital Identity Wallet ecosystem (in production in Italy), an RP obtains a citizen’s attributes from an identity (wallet) provider anchored to a national TA [35]. In open banking, a bank (OP) releases a customer’s account data to a third-party provider (RP) only after resolving that provider’s chain to the scheme’s TA (a model championed by Open Finance Brasil [36]).

Organizational Culture

Two different groups stand behind the standards associated with OAuth and OIDC: the OAuth Working Group, stewarded by the IETF, and the OpenID Foundation. Substantial overlap exists not only between the problems they address, but also between their members (e.g., Nat Sakimura is an author of both OpenID Connect Core 1.0 and various OAuth-related RFCs). Nonetheless, differences exist. The OpenID Foundation tends to be more identity- and authentication-centric, focusing on login flows and sessions. It also has a more

commercial attitude, financing itself through membership fees, certification programs, and member-funded projects [37]. In OAuth the focus is more on authorization and APIs, with the fundamental problem of how to delegate authorization at the center. Being part of the IETF, membership is free and financing relies on donations. SPIFFE and SPIRE do not come from a standards body but from an open-source project in which the specification (SPIFFE) and the reference implementation (SPIRE) evolved together. It is a community-driven Cloud Native Computing Foundation project whose cultural center of gravity is cloud-native infrastructure and zero-trust workload identity.

Token Exchange

Peer-to-peer validation, not mediated by an exchange process, is natural in OIDC. This is because since its inception, OIDC standardized the token format (JWT) and metadata/key discovery (OIDC Discovery). Those two aspects were not tamed by OAuth, which for nine years left implementers free to choose their token format and was perfectly happy with opaque tokens that could only be AS-validated; the JWT Profile for OAuth Access Tokens (RFC 9068) appeared only in 2021. Moreover, only in 2018 did OAuth adopt a metadata discovery mechanism (RFC 8414) very similar to the OIDC one. Because OIDC mandated both token format (JWT) and mandatory claims (e.g., `iss`, `sub`, `aud`) the need to exchange tokens was not a priority; RPs and OPs could understand each other's tokens and could validate them directly. On the contrary, exchanging tokens became a necessity for OAuth, where token-interoperability between domains was not provided by design. RFC 8693 standardized the STS concept, allowing a home domain to issue tokens in its own format to entities in a foreign domain. The interoperability problem still existed, but it was confined to the STS rather than remaining a system-wide concern. Token exchange has implications for the trust and operational model. Exchanging tokens gives the domain owner full control over its trust relations. Another advantage is that adding a new trusted issuer does not require downstream changes. The cost is that of managing the STS and potentially many heterogeneous policies. As WIF makes the case for it, token exchange is an IAM feature that facilitates bilateral trust relationships. Many-to-many trust models, such as those between members of SAML-like federations (e.g., eduGAIN), do not need token exchange. In those cases, there is a greater technical minimum common denominator agreed upon beforehand by federation members. In other words, all members "speak the same IAM language" and a translation layer is not needed. This can also be observed in OpenID Federation 1.0 where tokens are used directly.

Remote Attestation

SPIRE's attestation is local by construction: the agent and the workload it attests are assumed to be colocated [38]. Attesting a workload across a trust-domain boundary is instead the subject of remote attestation, whose terminology the IETF's Remote Attestation procedureS (RATS) architecture

standardizes in RFC 9334 [39]: an Attester produces Evidence about itself, a Verifier appraises that Evidence against references and produces Attestation Results, and a Relying Party consumes those results to decide. Implementations exist for both roles: Keylime, a CNCF project, uses TPM 2.0 to attest boot and runtime integrity of remote nodes [40], and Veraison, hosted by the Confidential Computing Consortium, provides a scheme-agnostic Verifier [41]. Work to carry attestation across identity boundaries is emerging: an experimental plugin makes a node's Keylime attestation state a precondition for SPIRE issuing identities on that node [42], and two unadopted Internet-Drafts targeting the IETF's Workload Identity in Multi System Environments (WIMSE) Working Group propose carrying RATS Evidence inside a Workload Identity Token [43] and chaining hardware evidence transitively to an SVID [44]. In all of them the relying party's trust in the appraising authority, be it a Verifier or the endorsement chain behind a hardware root, is bilateral and pre-configured: RFC 9334 reduces it to holding the Verifier's key in a trust anchor store, or to having the Verifier first act as an Attester towards the relying party [39, §7.1]. What is missing is a multilateral mechanism by which mutually distrusting domains agree on which Verifiers are acceptable; a recent individual draft sketches decentralized trust registries for this purpose but stops at architecture, specifying neither protocol nor governance [45]. That is the gap the ledger layer of Section IV addresses.

SAML Federation

The Security Assertion Markup Language (SAML) 2.0 is the long-standing standard for cross-organizational web single sign-on: an identity provider (IdP) signs an assertion vouching for a subject and a service provider (SP) consumes it, so one login reaches services across organizational boundaries. Trust rests on a pre-established circle of IdPs and SPs exchanging signed metadata ahead of time, which in large inter-federations (e.g., eduGAIN) a central operator aggregates and distributes. SAML thus exemplifies the closed-world federation this paper sets out to relax.

III. REQUIREMENTS AND RESEARCH QUESTIONS

The following requirements describe a future cross-domain trust establishment framework that fills the gaps and realizes the potential discussed in Section I.

- **R1:** unplanned interactions. A workload in domain X must talk to a workload in domain Y without prior pairwise configuration;
- **R2:** non-human interaction. No assumptions of interactive consent or browser redirects;
- **R3:** ephemerality. Workloads come and go, and identity must be decoupled from network locators;
- **R4:** heterogeneity. Trust domains may use different IAM solutions;
- **R5:** scale. Federation size grows to millions of non-human entities (NHEs);
- **R6:** fast trust-change propagation. Federation on-boarding, off-boarding, and key rotation must con-

verge across federation members and consumers within bounded time;

- **R7:** least-privilege authorization. Access is scoped; trust does not imply blanket access;
- **R8:** auditable governance. Federation membership and services must be inspectable by all members and consumers;
- **R9:** no single point of failure. No single party can unilaterally censor or partition the federation.

The first research question follows.

RQ1. Which IAM approach is the best foundation to extend toward dynamic federation establishment between trust domains, satisfying the requirements outlined in Section III and enabling access control (i.e., authentication and authorization) between workloads of different domains?

RQ1 is answered analytically. The requirements eliminate SAML and OpenID Federation 1.0, leaving SPIRE and WIF. What separates the two are two aspects that are hard to benchmark. The first is trust granularity. SPIRE roots trust in attestation of the specific workload, whereas WIF can only verify the assertions carried inside an exchanged token. The second is standardization coverage. SPIFFE/SPIRE specifies its own internals (the Server, the Agent, and how workloads are attested and provisioned), whereas WIF leaves provisioning to ambient, infrastructure-specific mechanisms and exchange-policy encoding to each provider (Section IV). The empirical evaluation therefore does not arbitrate RQ1. It validates the resulting design and measures WIF alongside it as an industry baseline.

Because none of the considered IAM solutions satisfactorily supports the trust-anchoring and governance requirements (R8, R9), a second, separate research question follows.

RQ2. How can a multi-stakeholder coordination mechanism between heterogeneous trust domains be designed to provide trust anchoring and metadata sharing?

IV. IAM SOLUTIONS AND PROPOSED DESIGN

Among the IAM solutions surveyed in Section II, SAML federations are not considered further. They are browser-centric, which R2 (non-human interaction) rules out, and presuppose a pre-established circle of members, which R1 (unplanned interactions) rules out. They also carry heavy member-management overhead, rest on older XML conventions, and in general are not designed for M2M APIs. On similar grounds, OpenID Federation 1.0 is also excluded. Any two domains wishing to interact must already have joined the federation, a manual on-boarding step, and must share a TA. This breaks R1 and R2 as well. The distinguishing feature of OpenID Federation 1.0 is precisely the PKI it defines, which this paper proposes to relocate onto a ledger. By contrast, SPIRE and WIF are less opinionated about how trust is rooted: each contributes an orthogonal primitive (attestation and token exchange) that leaves more control over how the anchors are realized. Both also bind identity to the workload rather than to its network location, as R3 requires.

The diagrams below show how SPIRE and WIF realize the discussed dynamic and unplanned trust establishment. Arrowheads point from initiator to responder (data may flow both ways); circled labels mark the non-standard interactions this paper proposes; components carry their federation-level authorization role per NIST SP 800-162 [46], local roles being omitted. A domain can have three, possibly concurrent, roles in a federation: member, provider, and consumer, with the sole constraint that a provider must be a member. In the diagrams, Domain B is a provider and Domain A is a consumer. There are two operational modes in which A can consume trust: Imperative and Inversion of Control (IoC). Under Imperative, the consumer invokes services in the federated/trusted Domain B. Under IoC, it is the federated/trusted domain that invokes services in the consumer. The diagrams visualize both modes simultaneously, disambiguating with dashed lines for the Imperative mode. The Policy Administration Point (PAP) is defined by NIST as a policy management interface [46]. As such, a principal (human or NHE) configures its relationship with respect to a federation (e.g., being a member or a consumer) by interacting with it. The publicly available federation metadata is where a provider declares the terms under which federated workloads may access its resources. For the IoC case, it is the sole configuration source for the consumer. The metadata must also specify whether imperative mode is supported and how a consumer gains authorization (e.g., federation members only, or any holder of a credential from a given issuer), the required request parameters (e.g., the *aud* and principal of an exchange request), and any external coordination procedure (e.g., payment settlement or interactive know-your-customer checks). Wherever the PAP configures a workload, the configuration may equivalently target an indirection layer: environment variables, or a local discovery service queried at runtime.

Interactions Common to Both

- enr) Domain B enrolls in the federation; its metadata enters the Repository.
- res) Via the PAP, the federation metadata is resolved and configures Domain A: its workloads learn which foreign domains exist and what they offer, and B's workloads become authenticable and authorizable under IoC.
- tcj) Trust Configuration Interface. Via the PAP, the foreign-domain URLs known to A's workloads are managed, enabling discovery as well as controls such as black-listing. In the most extreme, agentic realization, this arrow instead has Workload A configure its own domain's trust perimeter bottom-up, establishing technical trust in a previously unknown federation and breaking with the closed-world model in which joining a federation is a static decision.
- cor) Coordination between workloads: how Workload A requests that Workload B operate under IoC, and how Imperative-mode authorization is negotiated.

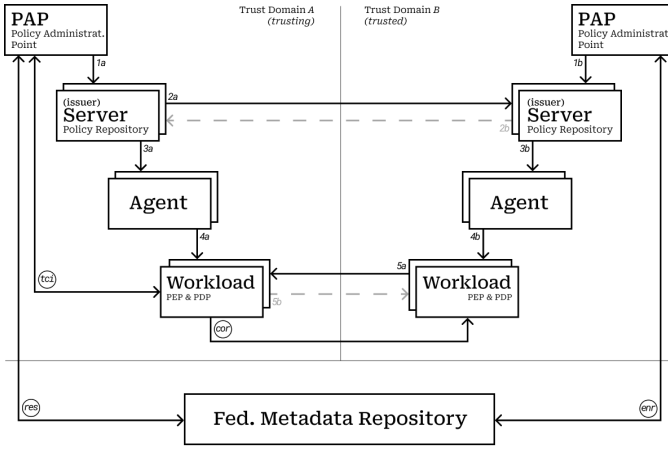


Fig. 1. SPIFFE/SPIRE communication diagram showing a federated trust domain (right) and a consumer (left). Circled labels mark proposed enhancements. Dashed lines refer to interactions only required for the Imperative mode.

SPIFFE & SPIRE

Although the trust relationship itself is asymmetric, whether the bootstrap must be symmetric, i.e., whether the two domains must pre-exchange bundles out of band, depends on the bundle endpoint's *endpoint profile*. The deciding factor is whether TLS to the bundle endpoint relies on web PKI. With *https_web*, the endpoint presents an ordinary X.509 certificate rooted in a public certificate authority (CA) (e.g., Let's Encrypt); a consumer can therefore validate the connection and fetch the bundle through web PKI alone, with no prior knowledge of the provider. SPIRE is then fully asymmetric: the provider needs no configuration about its consumers. With *https_spiffe*, the endpoint instead presents its own X.509-SVID, which is not anchored in a public CA. Validating it, therefore, requires already holding the bundle, a chicken-and-egg problem: a domain must obtain the foreign bundle out of band before it can fetch it. Bootstrap is thus symmetric, and both domains must be mutually configured.

- 1) The Server is bootstrapped (configured parameters include local domain name, node-attestations, workload registration entries, etc.). Under *https_spiffe*, configured parameters must also include the other server's bundle.
- 2) The Server fetches the bundle of the other domain. This must happen under *https_web*; under *https_spiffe* it is done to refresh a potentially stale bundle.
- 3) SPIRE Agent Attestation as per Section II.
- 4) SPIRE Workload Attestation as per Section II. In SPIRE, the Agent pushes local trust bundle updates to the workloads. This is in contrast to WIF where workloads have to fetch from the local JWKS endpoint (cf. arrow 4 of Figure 2).
- 5) Workload communication. Workload A acts as both enforcement and decision point (configured with the authorization rules from the Agent). Workload B initiates under IoC; Workload A under Imperative mode.

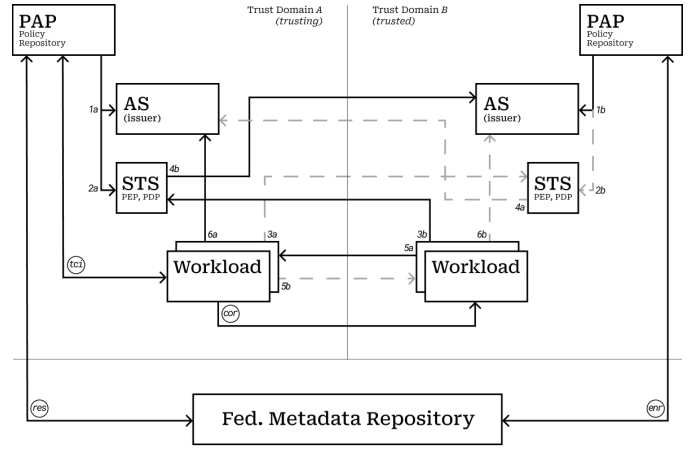


Fig. 2. WIF communication diagram showing a federated trust domain (right) and a consumer (left). Circled labels mark proposed enhancements. Dashed lines refer to interactions only required for the Imperative mode.

WIF

Whereas SPIRE's *https_spiffe* profile permits opting out of web PKI, WIF makes this dependency inescapable. The advantage is that mutual configuration between consumer and provider is never required. Note that the separation between STS and AS (i.e., the issuer) is logical, and deployments often combine them into a single component.

- 1) The AS is bootstrapped with essential data such as keys and the domain name.
- 2) The STS is configured with trusted issuer URLs, their configurations, and per-issuer policies for token exchange. In this design, the STS configuration is derived from the federation metadata. Nonetheless, domain A remains sovereign and may modify its STS policies as it sees fit. How policies are encoded remains an open design question, as RFC 8693, while standardizing the token-exchange protocol itself, does not prescribe how to encode exchange authorization policies (e.g., AWS uses a JSON IAM trust policy, GCP uses attribute conditions written in the Common Expression Language [47], [48]).
- 3) Workload B makes a token exchange request to A's STS. The request is evaluated against the configured policy. If successful, a token signed by Domain A AS is released.
- 4) After receiving an exchange request, the STS checks whether it originates from a trusted domain by inspecting the issuer URI of the presented token. Verifying the token's signature, however, requires the issuer's public key, which the STS may need to fetch from the requesting domain's JWKS endpoint.
- 5) After successfully exchanging a token, the workload can communicate with the other domain's workload, which, effectively, in the role of a Resource Server (as defined by RFC 6749), validates the received token against the local AS keys.
- 6) A Workload fetches from the local JWKS URI the AS

public keys. The JWKS URI is a *well-known* endpoint derived from the issuer URL. The diagram omits how this URL is learned. In most cases, it is derived from the *iss* field of the token the workload uses to authenticate with the AS (which, as stated before, is in most deployments obtained through ambient provisioning).

A noticeable difference from SPIRE is the amount of cross-domain interactions required. In SPIRE it was sufficient for the servers to fetch their respective bundles, but in WIF, the dance is more convoluted. The workload first calls the foreign STS (token exchange), then the foreign STS may fetch the key material from the requesting Issuer (if not cached).

a) *Workload Ambient Provisioning*: The diagram (and every OAuth and OIDC specification for that matter) assumes that the workloads are already provisioned with credentials, recognized by the local issuer, attesting their identity. Most deployments rely on the infrastructure to act as the Identity Provider (i.e., *infrastructure as IdP*); Kubernetes projected tokens [49] and link-local metadata endpoint (e.g., `http://metadata.google.internal/`) [50] are common examples. In some documents, this token is referred to as *ambient token* because it is provisioned by the environment (i.e., the infrastructure) on which the workload runs [51]. For this reason, the paper refers to this practice as *ambient provisioning*.

Federation in SPIRE and WIF

The defining difference in how SPIRE and WIF federate is token exchange. In WIF, a workload uses its local credential to obtain a target domain credential from the STS. Federation is thus mediated by a broker that decides how to map a foreign principal onto a local one. This token-exchange model forces the configuration in WIF to be two-sided and asymmetric. On the trusting side, the PAP configures a *trust policy* on the STS declaring which foreign issuers and claims to accept and how to map them onto a target principal. On the trusted side, the PAP configures a *federation client* that mainly carries the audience (the *aud* that will be requested) SPIRE federation, by contrast, involves neither a token exchange nor an STS. Trust domains exchange only *trust bundles*, the public keys (X.509 CA certificates and JWKS) required to verify a peer's SVID [52]. There is no identity translation: a workload keeps its own SPIFFE ID across the boundary, and the consumer verifies the peer directly over mTLS against the federated bundle. Configuration is therefore symmetric: both servers publish a bundle endpoint and configure the other domain's endpoint. SPIRE federation trusts an entire domain. WIF, by contrast, conditions its trust policy on issuer and claims, enabling fine-grained authorization. This expressiveness comes at a cost: the relationship is asymmetric and requires coordination between both parties.

Proposed Design: Attested Cross-Domain Identity

Composing SPIRE with WIF achieves access granularity, but at a cost: it abandons attestation exactly where it matters most. Neither gives a fine-grained decision anchored in attestation of the specific remote workload. The limit is

structural. Attestation requires observing the workload, which only a co-located agent can do; a token exchange offers no such observation, so the consuming domain merely verifies the assertions contained in the token. In contrast, the trust in an SVID is rooted in attestation. Composition also adds overhead: two trust planes, different credential formats and their mapping to operate, plus WIF's asymmetric, provider-specific configuration whose two sides must be coordinated. This paper proposes to extend SPIRE directly. A standardized token-exchange step, reusing RFC 8693 [32] bound to SPIFFE semantics, would bring WIF's expressiveness (conditioning on claims, mapping to a local principal, scoping to an audience) into the model, bridging domains that run different IAM solutions (R4) and keeping cross-domain access least-privilege (R7). Remote workload attestation would let a trust decision target a specific workload rather than a whole domain. Together, they yield cross-domain identity that is both fine-grained and attestation-based, under one credential and one open protocol. Both the token-exchange and remote attestation additions presuppose shared trust anchors. In a federation of potentially mutually distrusting domains lacking a common authority, this shared reference cannot be owned by any single member without making it a trusted third party with unilateral decision power, which is what R9 forbids. For this reason, shared key material and federation metadata are recorded on the ledger. This solves key exchange and makes updates tamper-evident and consistently readable by all members and consumers, as R8 requires. The federation lifecycle operations, such as on-boarding new members, become a multi-stakeholder access-control problem, which is solved by a dedicated governance layer, such as that described in [53]. Verifier trust anchors are part of that shared key material, and admitting or removing a Verifier is a governance action like admitting a member. A domain can therefore appraise Evidence produced in a foreign domain against a Verifier the federation collectively accepted, rather than one it configured bilaterally and out of band. These records change infrequently, so the ledger stays on the control plane, off the runtime path of exchange and attestation.

V. EVALUATION DESIGN

This evaluation does not select the IAM approach. RQ1 is settled analytically in Section IV: automatic, bottom-up workload attestation and a standard that also covers provisioning single out SPIRE as the base to extend. The evaluation instead validates that the extended SPIRE design meets R5 and R6, with WIF measured alongside as an industry baseline. At the same time, it answers RQ2 by evaluating the Federation Metadata Repository (FMR), which carries trust anchoring and governance, in its two forms: a centralized web server versus a distributed ledger.

The plan takes two perspectives, that of federation members and that of external consumers, and applies three measurement categories to both. The FMR is assumed to notify members of lifecycle events via Server-Sent Events when implemented

as a web server, or via Solidity events when implemented on a ledger.

Federation Operations. The latency of lifecycle operations (federation creation, member addition, key rotation, and member removal) is measured against federation size, to rank the candidates and expose their scaling properties (under SPIRE, for instance, each foreign domain adds an SVID field, anticipating increased overhead as federation size grows). Key rotation adds measurements of the internal propagation time (how long it takes for the local workload to pick up the rotated key), external propagation (how long it takes for foreign domains to do so), and full-mesh latency (how long it takes for the workloads affected by the key rotation to communicate with every other foreign workload using the new key). Full-mesh latency is asymmetric: under SPIRE, it is the time for the receiver to re-establish its federation configuration after a sender-side rotation, whereas under WIF, it is the time for the sender to re-exchange tokens after a receiver-side rotation. Member removal splits into propagation latency and empty-mesh latency (how long it takes for the removed member’s workloads to be unable to reach anyone).

Workload Under Load. Per-request validation should be constant, but shared resources on the validation path (introspection endpoints, JWKS caches, locks) may degrade non-linearly under load. With N senders driving one target, sender-side latency is plotted against load. A curve plotted with validation disabled fixes the setup’s baseline, and a curve with validation enabled sits above it, the gap being the validation cost. The measurement establishes whether that gap stays constant before it widens, and which candidate is cheaper. Separate setups are constructed to measure WIF with and without token introspection.

Active/Passive Revocation Trade-off. With token exchange, the exchanged token’s TTL serves as passive revocation; active revocation would instead introspect every request at the STS, at a cost. Throughput (application messages per second) is plotted against TTL. The active curve introspects on every request and is TTL-independent, a horizontal reference; the passive curve does not introspect and sweeps the TTL down, starting above the reference (as it does not bear the introspection overhead) but falling as shorter TTLs raise the re-exchange rate. Their crossing is the optimal TTL: the tightest TTL matching active-mode throughput. This applies only to WIF today; it would extend to SPIRE if SPIRE adopted token exchange.

VI. CONCLUSION AND FUTURE WORK

This paper claims that the future digital landscape will see deeper technical integration between systems. Because of this, and additionally motivated by the rise of large-language-model-based AI agents, supporting unplanned interactions between NHEs will become more relevant. The approach explored by this paper is to evolve the federation-building capabilities of today’s IAM solutions to enable a single trust domain to federate under loosely coupled groupings that agree

and coordinate on the essential trust parameters. After analyzing the most prominent IAM solutions, this paper answers RQ1: SPIRE is the most promising foundation to extend. Nonetheless, to satisfy the need for dynamism, automation, and control in trust-relationship management, SPIRE should be extended with remote attestation, token exchange, and, in answer to RQ2, a distributed ledger acting as the Federation Metadata Repository, anchoring the shared trust roots and carrying the governance actions that admit and remove members without any single domain owning that reference.

This paper presents a design, not an implementation. Building it end-to-end remains to be done, and the work is substantial. Four issues stand out: SPIRE remote attestation, SPIRE token exchange, the distributed-ledger layer that anchors trust roots and carries governance, and, not least, revocation. Revocation is the most tractable of these. SPIRE relies on short SVID lifetimes, letting credentials lapse rather than recalling them. Routing issuance through the STS adds finer control: a token can be revoked directly instead of waiting out its TTL. Token exchange must be brought into SPIRE, introducing an architectural element functionally equivalent to WIF’s STS to mint scoped, audience-bound tokens from a foreign workload’s SVID. The ledger layer likewise remains to be realized. Trust-root anchoring and the governance actions that admit or remove domains and Verifiers were described as ledger-backed, but the concrete choices are open: which ledger, which consensus algorithm, and which access-control model. Remote attestation is perhaps the most arduous task. SPIRE assumes Agents and Workloads are co-located. Remote attestation does not escape this. Transitive trust cannot be eliminated but only relocated; the guiding principle is to shift the basis of trust from an issuer’s assertion to attestation evidence produced by the workload itself. Practical directions include using a hardware anchor such as a trusted platform module, or delegating appraisal to a Verifier in the RATS sense. Which Verifier a domain accepts is not left to bilateral configuration: its trust anchor is recorded on the ledger and admitted through the same governance layer that admits members, so what remains open is the attestation machinery itself rather than the question of whom to trust to appraise it.

ACKNOWLEDGMENTS

This work was funded by the Federal Ministry of Education and Research (BMBF) in Germany under the grant number 16KIS2251 of the SUSTAINET_guarDian project.

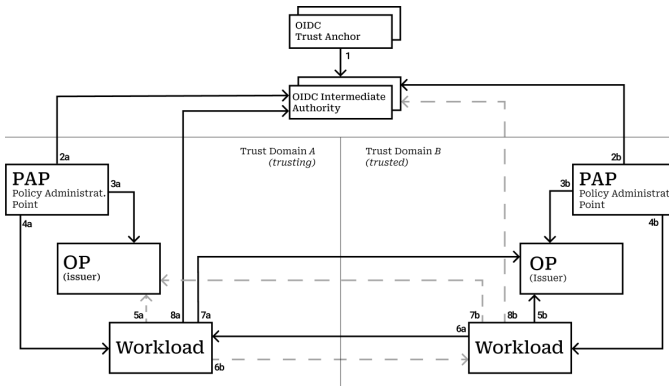


Fig. 3. OpenID Federation 1.0 communication diagram showing two federated trust domains where the right one initiates communication with the left one. Dashed lines refer to an interaction initiated by the left domain. OpenID Federation 1.0 requires bilateral membership (i.e., both A and B are members of the federation).

APPENDIX

OpenID Federation 1.0

- 1) A TA publishes its own self-signed Entity Configuration and Subordinate Statements defining its immediate subordinates (i.e., the intermediates).
- 2) Via the PAP, an out-of-band, manual request is made to an intermediate, requesting to be listed as a federation member.
- 3) Via the PAP, the OP is bootstrapped. Configurations include domain name, keys, and immediate superiors.
- 4) The PAP configures the Workload with the TAs.
- 5) The workload requests a federation-scoped access token from the OP. Ambient provisioning is not sufficient, as it would give the workload an identity credential that does not have the right audience to be used to talk to a federation member. This contrasts with WIF, where an ambient-provisioned token can be sent directly to the other domain's STS.
- 6) Workload B initiates communication with Workload A. The locally issued, federation-scoped credential (obtained in step 5) is included in the request. As per OpenID Federation 1.0, how Workload A's endpoint is discovered is out of scope.
- 7) Workload A fetches Domain B's Entity Statement, obtaining the signing keys to validate the credential received in step 6. Keys may be included directly in the entity configuration or fetched with a second request to the JWKS URI.
- 8) Step 7 alone is not sufficient to trust Workload B. Trust must be anchored to a TA. The intermediate authority that signed the entity statement (fetched in step 7) must be queried. It will return a list of valid subordinate entities in which B's OP must appear. Moreover, the entity statement of the intermediate is fetched, and it must be signed by a trusted TA. If successful, Workload A authorizes B's request received in step 6.

REFERENCES

- [1] D. D. Garcia-Swartz and M. Campbell-Kelly, *Cellular: an economic and business history of the international mobile-phone industry*. MIT Press, 2022.
- [2] "Telefónica case study," <https://cloud.google.com/customers/telefonica>, [Accessed 16-12-2025].
- [3] "AWS Wavelength," <https://aws.amazon.com/wavelength/>, [Accessed 16-12-2025].
- [4] K. Ganesan, J. Loehr, H.-N. Choi *et al.*, "5G advanced: Sidelink evolution," *IEEE Communications Standards Magazine*, vol. 7, no. 1, pp. 58–63, 2023. [Online]. Available: <https://doi.org/10.1109/MCOM.STD.0007.2200057>
- [5] Deutsche Telekom, US NSA, Lenovo, Ericsson, Huawei, HiSilicon, China Mobile, and Boost Mobile Network, "New key issue: Linking NF authentication to authorization in 6G," 3rd Generation Partnership Project (3GPP), Dalian, China, Tdoc, pCR S3-262608, May 2026. [Online]. Available: https://www.3gpp.org/ftp/tsg_sa/WG3_Security/TS_GS3_128_Dalian/Docs/S3-262608.zip
- [6] S. Rodriguez Garzon, H. Dinh Tuan, M. Mora Martinez, A. Küpper, H. J. Einsiedler, and D. Schneider, "Beyond certificates: 6G-ready access control for the service-based architecture with decentralized identifiers and verifiable credentials," in *2024 Joint European Conference on Networks and Communications & 6G Summit (EuCNC/6G Summit)*, 2024, pp. 830–835. [Online]. Available: <https://arxiv.org/abs/2310.19366>
- [7] F. *et al.*, "e-patients: How they can help us heal health care," https://participatorymedicine.org/e-Patients_White_Paper.pdf, [Accessed 30-03-2026].
- [8] T. Richards, V. M. Montori, F. Godlee, P. Lapsley, and D. Paul, "Let the patient revolution begin," 2013.
- [9] U.S. Food and Drug Administration, "The software precertification (Pre-Cert) pilot program: Tailored total product lifecycle approaches and key findings," U.S. Food and Drug Administration, Digital Health Center of Excellence, Final Report, Sep. 2022. [Online]. Available: <https://www.fda.gov/medical-devices/digital-health-center-excellence/digital-health-software-precertification-pre-cert-pilot-program>
- [10] M. Ayaz, M. F. Pasha, M. Y. Alzahrani, R. Budiarto, and D. Stiawan, "The fast health interoperability resources (FHIR) standard: Systematic literature review of implementations, applications, challenges and opportunities," *JMIR Medical Informatics*, vol. 9, no. 7, p. e21929, 2021. [Online]. Available: <https://doi.org/10.2196/21929>
- [11] C. Dinh-Le, R. Chuang, S. Chokshi, and D. Mann, "Wearable health technology and electronic health record integration: Scoping review and future directions," *JMIR mHealth and uHealth*, vol. 7, no. 9, p. e12861, 2019. [Online]. Available: <https://doi.org/10.2196/12861>
- [12] F. Fred Schulte, Erika Fry, "Death By 1,000 Clicks: Where Electronic Health Records Went Wrong - KFF Health News — kffhealthnews.org," <https://kffhealthnews.org/news/death-by-a-thousand-clicks/>, [Accessed 30-03-2026].
- [13] "Why patient matching is a key challenge in achieving interoperability - Health Data Management — [healthdatamanagement.com](https://www.healthdatamanagement.com/)," <https://www.healthdatamanagement.com/articles/why-patient-matching-is-a-key-challenge-in-achieving-interoperability?id=135986>, [Accessed 31-03-2026].
- [14] "4 Reasons Why EHR Interoperability is a Mess (and How to Fix It) — [rhapsody.health](https://rhapsody.health/blog/reasons-ehr-interoperability-is-a-mess-and-how-to-fix-it/)," <https://rhapsody.health/blog/reasons-ehr-interoperability-is-a-mess-and-how-to-fix-it/>, [Accessed 30-03-2026].
- [15] K. S. Thomas, S. Edpuganti, D. M. Puthooran, A. Thomas, A. Joy, and S. Latheef, "Artificial intelligence in modern clinical practice," *Medicine International*, vol. 6, no. 1, p. 5, 2025.
- [16] K. B. Johnson, W.-Q. Wei, D. Weeraratne, M. E. Frisse, K. Misulis, K. Rhee, J. Zhao, and J. L. Snowden, "Precision medicine, ai, and the future of personalized health care," *Clinical and translational science*, vol. 14, no. 1, pp. 86–93, 2021.
- [17] O. Lavoie-Gagne, J. J. Woo, R. J. Williams III, B. U. Nwachukwu, K. N. Kunze, and P. N. Ramkumar, "Artificial intelligence as a tool to mitigate administrative burden, optimize billing, reduce insurance- and credentialing-related expenses, and improve quality assurance within health care systems," *Arthroscopy*, vol. 41, no. 8, pp. 3270–3275, 2025. [Online]. Available: <https://arthroscopyjournals.onlinelibrary.wiley.com/doi/abs/10.1016/j.arthro.2025.02.038>
- [18] E. Crigger and C. Khoury, "Making policy on augmented intelligence in health care," *AMA Journal of Ethics*, vol. 21, no. 2, pp. E188–191,

2019. [Online]. Available: <https://journalofethics.ama-assn.org/article/making-policy-augmented-intelligence-health-care/2019-02>
- [19] S. Longpre, R. Mahari, A. Chen, N. Obeng-Marnu, D. Sileo, W. Brannon, N. Muennighoff, N. Khazam, J. Kabbara, K. Perisetla, X. Wu, E. Shippole, K. Bollacker, T. Wu, L. Villa, S. Pentland, and S. Hooker, "The data provenance initiative: A large scale audit of dataset licensing & attribution in ai," *arXiv preprint arXiv:2310.16787*, 2023.
- [20] J. Sevilla, L. Heim, A. Ho, T. Besiroglu, M. Hobbhahn, and P. Villalobos, "Compute trends across three eras of machine learning," in *2022 International Joint Conference on Neural Networks (IJCNN)*. IEEE, 2022, pp. 1–8.
- [21] NVIDIA Corporation, "Nvidia announces financial results for fourth quarter and fiscal year 2025," Press release, Form 8-K, U.S. Securities and Exchange Commission, 2025. [Online]. Available: <https://www.sec.gov/Archives/edgar/data/0001045810/000104581025000021/q4fy25pr.htm>
- [22] I. Arrieta-Ibarra, L. Goff, D. Jiménez-Hernández, J. Lanier, and E. G. Weyl, "Should we treat data as labor? moving beyond 'free'," *AEA Papers and Proceedings*, vol. 108, pp. 38–42, 2018.
- [23] A. Ehtesham, A. Singh, G. K. Gupta, and S. Kumar, "A survey of agent interoperability protocols: Model Context Protocol (MCP), Agent Communication Protocol (ACP), Agent-to-Agent Protocol (A2A), and Agent Network Protocol (ANP)," 2025. [Online]. Available: <https://arxiv.org/abs/2505.02279>
- [24] Google for Developers. Announcing the Agent2Agent protocol (A2A): A new era of agent interoperability. [Online]. Available: <https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability/>
- [25] Cloud Security Alliance, "Threat modeling google's A2A protocol with the MAESTRO framework," Cloud Security Alliance Blog, Apr. 2025, accessed: 2026-06-10. [Online]. Available: <https://cloudsecurityalliance.org/blog/2025/04/30/threat-modeling-google-s-a2a-protocol-with-the-maestro-framework>
- [26] G. Chang, E. Lin, C. Yuan, R. Cai, B. Chen, X. Xie, and Y. Zhang, "Agent Network Protocol technical white paper," 2025. [Online]. Available: <https://arxiv.org/abs/2508.00007>
- [27] S. R. Garzon, A. Vaziry, E. M. Kuzu, D. E. Gehrman, B. Varkan, A. Gaballa, and A. Küpper, "Ai agents with decentralized identifiers and verifiable credentials," 2025. [Online]. Available: <https://arxiv.org/abs/2511.02841>
- [28] A. Babakian, P. Monclus, R. Braun, and J. Lipman, "A retrospective on workload identifiers: From data center to cloud-native networks," *IEEE Access*, vol. 10, pp. 105 518–105 527, 2022. [Online]. Available: <https://doi.org/10.1109/ACCESS.2022.3211293>
- [29] SPIFFE Project, "Scaling spire," https://spiffe.io/docs/latest/planning/scaling_spire/, accessed: 2026-06-05.
- [30] D. Hardt, "The OAuth 2.0 Authorization Framework," RFC 6749, Oct. 2012. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6749.html>
- [31] Google Cloud. Workload identity federation. Google Cloud IAM Documentation. [Online]. Available: <https://cloud.google.com/iam/docs/workload-identity-federation>
- [32] M. Jones, A. Nadalin, B. Campbell, J. Bradley, and C. Mortimore, "OAuth 2.0 Token Exchange," Internet Engineering Task Force (IETF), RFC 8693, Jan. 2020, proposed Standard. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8693>
- [33] N. Sakimura, J. Bradley, M. Jones, B. de Medeiros, and C. Mortimore, "OpenID Connect Core 1.0 incorporating errata set 2," OpenID Foundation, 2023, accessed: 2026-05-21. [Online]. Available: https://openid.net/specs/openid-connect-core-1_0.html
- [34] R. Hedberg, M. B. Jones, A. Å. Solberg, J. Bradley, G. De Marco, and V. Dzhuvinov. OpenID Federation 1.0. OpenID Foundation. [Online]. Available: https://openid.net/specs/openid-federation-1_0-final.html
- [35] Developers Italia, "spid-cie-oidc-django: The SPID/CIE OpenID connect federation SDK," GitHub repository, 2024, Italy's SPID/CIE national digital identity on OpenID Federation; led by G. De Marco. [Online]. Available: <https://github.com/italia/spid-cie-oidc-django>
- [36] Raidiam, "OpenID federation — the missing link for scalable trust in data, AI, and wallet ecosystems," Raidiam Developers Blog, 2025, raidiam operates the Open Finance Brasil trust directory. [Online]. Available: <https://www.raidiam.com/developers/blog/open-id-federation-the-missing-link-for-scalable-trust-in-data-ai-and-wallet-ecosystems>
- [37] OpenID Foundation, "About OpenID," <https://openid.net/foundation/>, 2023, accessed: 2026-05-30.
- [38] SPIFFE. SPIRE concepts. Cloud Native Computing Foundation. [Online]. Available: <https://spiffe.io/docs/latest/spire-about/spire-concepts/>
- [39] H. Birkholz, D. Thaler, M. Richardson, N. Smith, and W. Pan, "Remote Attestation procedureS (RATS) Architecture," Internet Engineering Task Force (IETF), RFC 9334, Jan. 2023. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc9334>
- [40] Keylime. Keylime: Remote boot attestation and runtime integrity measurement. Cloud Native Computing Foundation. [Online]. Available: <https://keylime.dev/>
- [41] Project Veraison. Veraison: Attestation verification services. Confidential Computing Consortium, Linux Foundation. [Online]. Available: <https://www.veraison-project.org/>
- [42] L. Bulwahn and A. Robb. (2025, Jan.) SPIFFE/SPIRE and Keylime: Software identity based on secure machine state. Red Hat Emerging Technologies. [Online]. Available: <https://next.redhat.com/2025/01/24/spiffe-spire-and-keylime-software-identity-based-on-secure-machine-state/>
- [43] D. Liu, H. Zhu, and J. Jin, "Carrying Remote Attestation Evidence in Workload Identity Tokens (WIT)," Internet Engineering Task Force (IETF), Internet-Draft draft-liu-wimse-wit-attestation-00, Mar. 2026. [Online]. Available: <https://datatracker.ietf.org/doc/draft-liu-wimse-wit-attestation/>
- [44] R. Krishnan, A. Prasad, D. Lopez, and S. Addepalli, "Transitive Attestation for Sovereign Workloads: A WIMSE Profile," Internet Engineering Task Force (IETF), Internet-Draft draft-mw-wimse-transitive-attestation-00, Feb. 2026. [Online]. Available: <https://datatracker.ietf.org/doc/draft-mw-wimse-transitive-attestation/>
- [45] D. Lu, "Federated Infrastructure Layer for Cross-Platform Device and Application Attestation," Internet Engineering Task Force (IETF), Internet-Draft draft-lu-rats-federated-attestation-infrastructure-00, May 2026. [Online]. Available: <https://datatracker.ietf.org/doc/draft-lu-rats-federated-attestation-infrastructure/>
- [46] V. C. Hu, D. Ferraiolo, R. Kuhn, A. Schnitzer, K. Sandlin, R. Miller, and K. Scarfone, "Guide to Attribute Based Access Control (ABAC) Definition and Considerations," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-162, 2014. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-162>
- [47] Amazon Web Services, "IAM roles: Terms and concepts — trust policy," 2026, accessed: 2026-05-21. [Online]. Available: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_terms-and-concepts.html
- [48] Google Cloud, "Workload identity federation: Configure providers," 2026, accessed: 2026-05-21. [Online]. Available: <https://docs.cloud.google.com/iam/docs/workload-identity-federation-with-other-providers>
- [49] The Kubernetes Authors, "Configure service accounts for pods: Service account token volume projection," 2026, accessed: 2026-05-21. [Online]. Available: <https://kubernetes.io/docs/tasks/configure-pod-container/configure-service-account>
- [50] Google Cloud, "VM metadata server overview," 2026, accessed: 2026-05-21. [Online]. Available: <https://cloud.google.com/compute/docs/metadata/overview>
- [51] Anthropic, "Workload identity federation," 2026, accessed: 2026-05-21. [Online]. Available: <https://platform.claude.com/docs/en/manage-claude/workload-identity-federation>
- [52] E. Gilman and A. Harding, "SPIFFE: In theory and in practice," CNCF [Cloud Native Computing Foundation] YouTube Channel, Oct. 2021, presented at KubeCon + CloudNativeCon North America 2021. Accessed: May 18, 2026. [Online]. Available: <https://www.youtube.com/watch?v=DXE6CDJjDV4>
- [53] C. Segat, S. Rodriguez Garzon, and A. Küpper, "Programmable governance for group-controlled decentralized identifiers," 2025. [Online]. Available: <https://arxiv.org/abs/2507.06001>